

Etat de l'art des attaques 5G

Contents

2.1	Les plateformes open source comme une approximation du réel	2
2.1.1	IPSec	3
2.1.2	Session Report	3
2.1.3	Allocation aléatoire des Identifiants de Session (SEID)	3
2.1.4	NF Heartbeat	4
2.1.5	Transport Layer Security (TLS)	4
2.1.6	Autorisation des NF avec OAuth 2.0	4
2.1.7	Présence du Service Communication Proxy (SCP)	5
2.2	Distinction entre attaques réalistes et hypothèses irréalistes	5
2.2.1	Attaques spécifiques aux implémentations	5
2.2.2	Attaques spécifiques aux standards	6
2.3	Les limites de MITRE en tant que framework de catégorisation	8
2.3.1	Absence de techniques bien connues	8
2.3.2	Status incorrects des techniques	8
2.3.3	Manque de détails sur les caractéristiques des techniques . . .	8
2.3.4	Pourquoi et comment caractériser nos attaques	8
2.4	Nouvelle classification propre aux enjeux de détections . .	8
2.4.1	Anomalies sémantiques	8
2.4.2	Anomalies séquentielles	8
2.4.3	Anomalies topologiques	8
2.5	Conclusion	8

Les opérateurs de télécommunications divulguent très peu d'information au sujet de leurs implémentations ainsi que sur les attaques auxquelles ils sont confrontés. Cette « sécurité par l'obscurité » limite l'émergence de menaces opportunistes et préserve des avantages concurrentiels. Toutefois, elle constitue également un frein important pour la recherche académique. En l'absence de données empiriques et de retours d'expérience concrets, de nombreux travaux proposent des scénarios d'attaque théoriques sans disposer de cadre de référence solide, rendant difficile l'estimation de leur réalisme et de leur applicabilité dans des environnements opérationnels.

Ce flou de l'état de l'art en matière de réalisme est accentué par une caractérisation parfois insuffisante des attaques dans la littérature scientifique. Certains travaux reposent sur des modèles d'attaquants incomplets, des hypothèses peu explicites ou encore des expérimentations menées sur des implémentations open source trop peu matures. Bien qu'il existe des cadres méthodologiques dédiés à la caractérisation des attaques tels que FIGHT, ceux-ci présentent encore des limites et demeurent, à notre connaissance, très peu adoptés dans l'état de l'art. Cette situation contribue à entretenir une certaine ambiguïté quant à la définition et à la classification des attaques réellement pertinentes dans le contexte de la 5G.

Par ailleurs, les approches traditionnelles de détection d'anomalies reposent majoritairement sur l'analyse de flux à grande échelle, fondée sur des indicateurs volumétriques. Cependant, la softwarisation des réseaux 5G rapproche ces infrastructures de systèmes distribués complexes, ce qui nécessite désormais une analyse plus fine, notamment au niveau des paquets. Afin de répondre à ce changement de paradigme, nous proposons une nouvelle catégorisation en trois classes d'attaques : sémantiques, séquentielles et topologiques, chacune présentant des problématiques spécifiques en matière de détection.

2.1 Les plateformes open source comme une approximation du réel

Afin de soutenir l'expérimentation et d'accélérer la recherche sur les réseaux 5G, plusieurs projets open source ont été développés, proposant des implémentations fonctionnelles à la fois du RAN et du CN. Ces plateformes sont devenues des outils essentiels pour le monde académique, permettant de mener des expérimentations sans dépendre d'équipements propriétaires coûteux. Parmi les implémentations de cœur de réseau les plus populaires figurent OAI[?], free5GC[?] et Open5GS[?]. Ces dernières peuvent être associées à un RAN réel comme srsRAN[?] ou OAI-RAN[?], connecté à du matériel radio et qui exploite vraiment la couche physique radio. Il existe néanmoins aussi des alternatives simulées, telles que UERANSIM[?], qui émulent la couche physique radio via TCP.

Ces initiatives sont particulièrement importantes. Toutefois, il est nécessaire de garder à l'esprit qu'il s'agit de projets collaboratifs, à but non lucratif et dont l'objectif est d'implémenter des systèmes complexes. Par conséquent, ils ne peuvent pas couvrir tous les aspects de manière exhaustive. Leur priorité est avant tout de proposer un code fonctionnel offrant un maximum de fonctionnalités. La sécurité, bien qu'importante dans un cadre opérationnel, constitue chez eux une contrainte parmi d'autres qui n'est pas toujours prioritaire dans ce contexte non commercial.

De ce fait, de nombreux mécanismes de sécurité définis par la norme 3GPP ne sont pas implémentés dans les différentes solutions open source. Le tableau ?? illustre ce problème en mettant en évidence l'absence de certains mécanismes dans les trois implémentations de CN les plus répandues. Afin de mieux appréhender les implications de ces lacunes, chacun des mécanismes présentés dans ce tableau est

2.1. Les plateformes open source comme une approximation du réel 3

Mécanisme	Open5GS	free5GC	OAI	Standards
IPSec par accès 3GPP	✗	✗	✗	Rel. 15 (2018)
PFCP Session Report	✗	v3.3.0 (2022)	v2.0 (2023)	Rel. 15 (2018)
SEID aléatoire	v1.1.0 (2019)	✗	✗	Rel. 15 (2018)
NF Heartbeat	v2.6.1 (2022)	✗	v1.1.0 (2021)	Rel. 15 (2018)
TLS	v2.6.1 (2022)	v3.1.0 (2022)	v2.3.0 (2025)	Rel. 15 (2018)
OAuth2	✗	v3.4.0 (2024)	✗	Rel. 15 (2018)
Fonction réseau SCP	v2.4.9 (2022)	✗	✗	Rel. 16 (2020)

Table 2.1: Date d’implémentation de mécanismes de sécurité dans les implémentations CN open source vis à vis de leur date de parution dans les standards 3GPP.

décrit individuellement dans les sous-sections suivantes.

2.1.1 IPSec

Selon la norme TS 33.501[?], les interfaces non basées sur les services, telles que N2, N3 et N4, doivent assurer des mécanismes d’intégrité, de protection contre le rejeu et de confidentialité. Plus précisément, IPSec en mode tunnel est requis pour N2 et N3, et n’est obligatoire pour N4 que si la sécurité n’est pas assurée par d’autres moyens. Parmi les implémentations open source étudiées, seule free5GC propose IPSec. Toutefois, celui-ci est uniquement disponible via les fonctions réseau N3IWF et TNGF, qui sont utilisées pour des équipements non conformes 3GPP. En pratique, la majorité des attaques proposées dans l’état de l’art que nous avons examinées déploient le cœur de réseau 5G avec un simulateur de RAN, tel que UERANSIM, qui se connecte directement à l’AMF et à l’UPF sans utiliser IPSec.

2.1.2 Session Report

Les procédures de *Session Report* sont définies dans la norme TS 29.244[?] et sont initiées par le SMF afin de synchroniser sa table de sessions locale avec celle de l’UPF. Régulièrement, et pour chaque session de sa table local, le SMF envoie une requête sur l’interface N4 afin de vérifier l’état de la session du point de vue de l’UPF. Ce mécanisme, n’a pas sans doute pas été conçu initialement à des fins de sécurité, mais y contribue néanmoins en supprimant les sessions obsolètes de l’UPF. Ainsi, les *Session Report* peuvent atténuer les attaques de type *PFCP Session Establishment Flood* en supprimant les sessions frauduleuses qui auraient pu être injectées dans l’UPF par un attaquant. Ce mécanisme n’est implémenté que dans free5GC et OAI.

2.1.3 Allocation aléatoire des Identifiants de Session (SEID)

Le SMF et l’UPF maintiennent chacun une liste locale d’identifiants uniques (SEID) permettant de désigner les sessions qu’ils gèrent. Pour interagir avec une

session existante, une NF initiatrice de communication doit connaître le SEID correspondant. La norme TS 29.244[?] spécifie que le SEID doit être codé sur 8 octets, ce qui implique en théorie une faible probabilité de collision si les valeurs sont uniformément réparties sur l'ensemble de l'espace. Néanmoins, même dans les versions les plus récentes, le 3GPP ne précise pas de méthode d'attribution des SEID. En conséquence, les implémentations varient : free5GC et OAI attribuent des SEID de manière incrémentale à partir de 0, tandis qu'Open5GS les génère de manière pseudo-aléatoire mais n'utilise que 12 bits sur 64, ce qui les rend prédictibles.

2.1.4 NF Heartbeat

La norme TS 29.510[?] stipule que chaque NF enregistrée dans le NRF doit envoyer régulièrement des *heartbeats* afin de prouver qu'elle est toujours active. Grâce à ce mécanisme, si une fonction légitime a été désenregistrée par un attaquant, elle se réenregistrera automatiquement lors de l'envoi du prochain *heartbeat*. Ce mécanisme n'est pas conçu exclusivement à des fins de sécurité, mais il permet implicitement de prévenir certaines attaques de DoS basiques qui désenregistrent simplement des NF légitimes. Parmi les implémentations que nous avons étudiées, seule free5GC n'implémente pas les *NF heartbeats*.

2.1.5 Transport Layer Security (TLS)

Selon la norme 3GPP TS 33.501[?], TLS doit être implémenté par chaque NF avec des certificats côté client et côté serveur. Ce protocole permet l'authentification, le chiffrement et la protection de l'intégrité des données, réduisant fortement le risque qu'un attaquant interagisse de manière malveillante avec les API des autres NF. Ce mécanisme est implémenté dans toutes les implémentations étudiées, mais il est à chaque fois désactivé par défaut.

2.1.6 Autorisation des NF avec OAuth 2.0

L'autorisation des NF est renforcée par l'utilisation d'OAuth 2.0 pour les appels aux API REST. Alors que TLS garantit que la NF est connue et légitime, OAuth permet de préciser les permissions de chaque entité et d'identifier les services accessibles par une NF. Comme décrit dans la norme 3GPP TS 33.501[?], le NRF agit en tant que serveur d'autorisation et délivre des jetons chiffrés contenant des informations détaillées sur les privilèges de la NF appelante. Parmi les implémentations étudiées, seule free5GC utilise ces jetons OAuth. Toutefois, leur version actuelle ne vérifie pas les permissions contenus dans les jetons lors des requêtes, rendant caduque l'utilisation d'OAuth.

2.1.7 Présence du Service Communication Proxy (SCP)

Dans le plan de contrôle du CN, les NF communiquent selon quatre modèles architecturaux (A, B, C et D), qui diffèrent par la manière dont la découverte, la sélection et le routage sont effectués (3GPP TS 23.501 [?]). L'approche recommandée par le standard introduit une NF dédiée, appelée *Service Communication Proxy* (SCP), qui agit comme intermédiaire pour les communications SBI entre NF et ajoute une couche supplémentaire de contrôle d'accès et de supervision. Parmi les implémentations étudiées, seule Open5GS suit le modèle de communication D proposé par 3GPP.

À travers les sections précédentes et le tableau ??, nous avons montré que le niveau de maturité des plateformes 5G disponibles dans l'état de l'art varie significativement. Chaque plateforme présente au moins trois mécanismes absents dans son implémentation, et les mécanismes manquants diffèrent d'une plateforme à l'autre. Cette hétérogénéité rend ces plateformes inadaptées comme outils intrinsèques d'évaluation des attaques et souligne la nécessité, dans le cadre de travaux de recherche orientés sur les attaques, de se référer aux spécifications 3GPP.

2.2 Distinction entre attaques réalistes et hypothèses irréalistes

Plusieurs travaux récents ont analysé des vulnérabilités 5G à travers des attaques théoriques et pratiques. Nous les classons en deux catégories : (i) les attaques exploitant des failles spécifiques aux implémentations open source, et (ii) les attaques exploitant des faiblesses inhérentes aux spécifications 3GPP. L'objectif de cette classification est de mettre en évidence les biais de raisonnement qui conduisent à confondre des attaques irréalistes avec des failles majeures des standards.

2.2.1 Attaques spécifiques aux implémentations

Coldwell et al. [?] ainsi que CTD5G [?] exploitent différentes NF de free5GC via des appels API malveillants qui incluent la manipulation de la gestion des NF, le scan et l'extraction de données utilisateurs. Ces attaques réussissent sur la version par défaut de free5GC, qui ne dispose ni de TLS, ni d'OAuth, ni de SCP, et ne permet donc pas d'authentifier correctement les NF. De plus, l'absence de mécanismes de *heartbeat* rend possible la suppression de NF légitime qui se reconnecteraient pourtant automatiquement en temps normale.

Amponis et al. [?] décrivent deux attaques basées sur PFCP ciblant la gestion des sessions entre le SMF et l'UPF. La première classe d'attaques tente de modifier ou supprimer des sessions, nécessitant la connaissance du SEID correspondant. Ces attaques ont été démontrées avec succès sur Open5GS, mais l'implémentation n'utilise que 12 bits sur 64 pour le SEID, rendant collisions et découvertes par force brute beaucoup plus faciles. La seconde classe d'attaques proposée par Amponis et

al. [?] vise à épuiser les ressources de l'UPF en établissant de manière répétée un grand nombre de sessions. Cette attaque n'est plausible que sur certaines implémentations, comme Open5GS, qui ne supportent pas les *PFCP Session Report* et ne suppriment donc pas les sessions inutilisées.

ZDI-CAN-18522 [?] décrit une vulnérabilité de réflexion de paquets permettant aux attaquants d'usurper un UE pour une communication uplink. L'attaquant peut créer des paquets avec l'IP de l'UE victime comme source et les envoyer via un tunnel utilisateur valide. L'UPF transmet alors ce trafic vers un hôte Internet arbitraire, créant un canal uplink falsifié au nom du dispositif. Cette attaque n'est possible qu'en l'absence d'authentification et d'intégrité et n'est donc pas possible sur une implémentation qui intègre IPSec conformément aux standards 3GPP.

Salazar et al. [?] présentent deux attaques spécifiques aux implémentations. La première envoie des messages NGAP mal formés pour déclencher une vulnérabilité des parseurs de free5GC et Open5GS, provoquant un crash de l'AMF. La seconde consiste à connecter et déconnecter de manière répétée un grand nombre d'UE, surchargeant le réseau et ciblant des déploiements 5G mal dimensionnés incapables de gérer un grand nombre d'utilisateurs.

Les attaques décrites dans ces travaux dépendent de conditions très spécifiques et exploitent souvent des implémentations encore immatures. Il est important de les distinguer des failles ciblant les standards, qui ont un impact plus large. Cette distinction est rarement établie dans la littérature.

2.2.2 Attaques spécifiques aux standards

Les spécifications 3GPP sont considérées comme exhaustives et couvrent de nombreux cas d'usage. Pourtant, plusieurs études ont identifié des vulnérabilités qui peuvent survenir même dans des déploiements respectant strictement les recommandations 3GPP.

Park et al. [?] exploitent le fait que l'encapsulation de tout autre trafic que celui des utilisateurs dans les couches GTP-U constitue une zone ambiguë des spécifications 3GPP (TS 29.281)[?]. De fait, la plupart des UPF n'inspectent pas les en-têtes GTP imbriqués et considèrent l'en-tête GTP-U interne comme une charge utile opaque, sans validation supplémentaire. Park et al. montrent ainsi que l'encapsulation de protocoles tels que PFCP, NGAP, ou même d'une autre couche GTP-U à l'intérieur de GTP-U permet à un attaquant de transmettre des requêtes à des NF critiques sans y avoir un accès direct. Ces attaques restent efficaces même lorsque IPSec est déployé car ce dernier protège les communications entre acteurs légitimes mais n'est d'aucun secours si ces derniers sont compromis.

Fan et al. [?] identifient deux vulnérabilités critiques dans le 5G. La première provient de la réutilisation du flux de clés dans la couche NAS : lorsque le processus *Security Mode Command* (SMC) échoue, l'UE réinitialise le compteur à zéro, mais la clé elle-même n'est pas nécessairement renouvelée selon TS 33.501[?]. Par conséquent, les messages retransmis utilisent le même flux de clés, permettant à un attaquant de déchiffrer ou de manipuler les messages de signalisation. La seconde

vulnérabilité découle de la gestion des messages liés à la protection d'intégrité. Selon TS 24.501[?], le CN 5G peut ne pas rejeter immédiatement ces messages, mais tenter d'abord une vérification d'identité. Cette ambiguïté permet à un attaquant, une fois le flux de clés dérivé, d'injecter des requêtes de désenregistrement falsifiées, causant potentiellement un DoS ou des transitions d'état incorrectes de l'UE.

Chlosta et al. [?] présentent l'attaque *SUCI-Catcher*, qui permet de découvrir des identifiants utilisateurs et de les utiliser pour de la géolocalisation. L'attaque exploite le fait que les messages d'enregistrement NAS de l'UE sont échangés avant l'établissement de clés, conformément à TS 33.501[?], ce qui permet à un gNB malveillant de lire le *Subscriber Concealed Identifier* (SUCI). Bien que le SUCI soit censé être chiffré, il est à ce moment là encore envoyé en clair, permettant à l'attaquant de récupérer des informations identifiantes.

Hussain et al. [?] introduisent 5GReasoner, un cadre de vérification formelle guidé par les propriétés pour les protocoles du plan de contrôle 5G. En l'appliquant aux spécifications 3GPP, ils ont découvert plusieurs attaques qu'un gNB malveillant peut exécuter. Ils ont notamment identifié des vulnérabilités de dépassement de compteur NAS dans TS 33.501[?], permettant à un attaquant de désynchroniser les compteurs entre l'UE et l'AMF, ce qui rend possibles plusieurs formes de DoS.

Ces attaques illustrent des vulnérabilités systémiques qui ne dépendent pas d'un contexte particulier et sont, en pratique, beaucoup plus susceptibles d'être exploitées. C'est précisément ce type d'attaques qui présente le plus d'intérêt pour la recherche, car il contribue significativement au renforcement et à la maturation continue du standard 3GPP.

2.3 Les limites de MITRE en tant que framework de catégorisation

2.3.1 Absence de techniques bien connues

2.3.2 Status incorrects des techniques

2.3.3 Manque de détails sur les caractéristiques des techniques

2.3.4 Pourquoi et comment caractériser nos attaques

2.4 Nouvelle classification propre aux enjeux de détections

2.4.1 Anomalies sémantiques

2.4.2 Anomalies séquentielles

2.4.3 Anomalies topologiques

2.5 Conclusion